M3-PI Guard

阶段性研究报告

面向 SCI JCR Q2 网络安全期刊的研究定位、工程证据与实验路线

拟定英文标题 Evaluating Runtime Authorization Under Context and Provenance Uncertainty for Tool-Using LLM Agents

---

报告日期：2026 年 7 月 24 日

证据截止：v7 候选已冻结；v7 全量离线审计与 API 实验尚未完成

报告版本：1.0

执行摘要

核心结论

以“运行时授权不确定性评估 + 来源感知、权限单调的防御机制”为主线，M3-PI Guard 具备冲击 SCI JCR Q2 网络安全期刊的条件，但当前只能判定为“有条件可行”。工程协议、证据链和中型实验基础已较成熟；决定论文能否成立的正式比较结果、跨模型验证、公共基准、自适应攻击和独立盲测尚未完成。

截至本报告，已经完成 34 篇直接相关文献的分级矩阵、22 个在线状态审计单元、六条件中型实验协议、DeepSeek 官方 API 的可审计证据链、v4–v6 失败版本的不可变封存，以及 v7 的新适配器、候选和准入冻结。最近一次完整且完成的全量回归为 1049 项通过、1 项跳过、0 项验证失败；v7 专项测试为 12/12 通过。

需要特别强调：现有数据只支持技术审计和运行质量分析，不支持 M3 的安全性、效用或领先性结论。v4、v5、v6 均因不同的协议或证据格式问题被判定为结果不准入；v7 尚未调用 API。

判断维度	当前判断	研究决策
期刊方向	网络安全方向匹配	首选 JISA；投稿前由机构订阅复核当期 JCR Q2
创新叙事	可成立但边界收紧	不主张“首个来源追踪”或“SOTA”，强调 oracle-free 评估与配对消融
工程证据	较强	冻结、哈希、准入、append-only 日志和失败留分母已成体系

科学证据	尚未形成	必须完成 v7 正式矩阵、公共基准、跨模型及自适应攻击
主要风险	效果可能来自过度阻断	以 TCR 非劣、ASK 负担和 policy-only/full 消融约束主张
备用论文路线	可保留	若机制无优势，转为授权泄漏、不确定性与安全—效用权衡实证研究

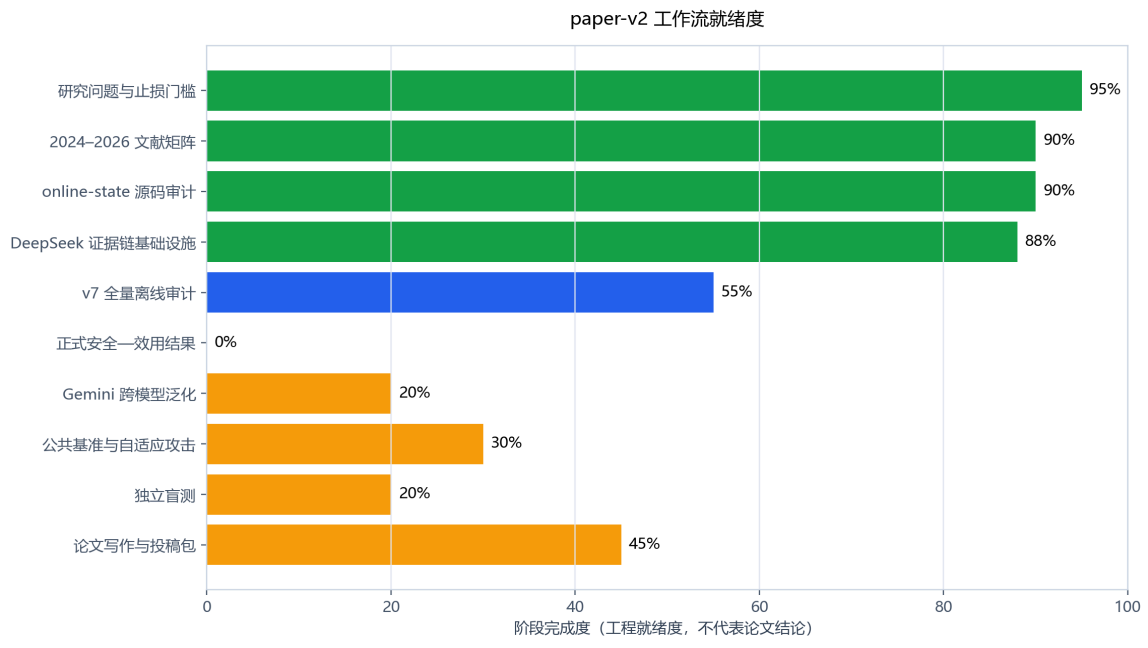


图1 当前阶段就绪度。图中百分比是项目管理估计，不是论文效果或统计结论。

本报告的阅读边界

- “工程就绪”表示接口、门禁、日志、哈希和测试具备继续实验的条件；不等价于防御有效。
- v4–v6 的记录用于定位实验协议缺陷，不进入论文主结果表，也不被删除或重写。
- 所有后续 API 调用仅限合成/公共研究数据，无工具执行、无真实外部副作用；模型输出只作为不可信动作提案。
- DeepSeek 的正式请求链采用：调用前冻结的本地 request ID + payload hash + 官方 response ID + 精确模型身份 + append-only 日志。

目录

章节	内容
1	项目定位、论文问题与可发表贡献
2	前沿研究版图与创新边界
3	已完成的研究与工程工作

4	实验架构、证据链与安全边界
5	v4–v7 技术演进与失败分析
6	当前数据、成本与验证状态
7	SCI JCR Q2 可行性评估与投稿策略
8	后续正式实验详细方案
9	恢复运行时的执行顺序
10	风险、止损与论文转向规则
11	阶段结论
附录	研究问题、统计规范、证据索引与核心参考文献

1 项目定位、论文问题与可发表贡献

1.1 论文定位

M3-PI Guard 研究工具型 LLM Agent 在间接提示注入环境下的运行时授权问题。系统不把模型输出直接视为可执行命令，而是将其视为需要经过策略、来源、时序、数据流和确认机制联合审查的动作提案。研究重点是实际执行安全，而不是单纯检测文本是否“像攻击”。

拟投稿方向优先选择 Journal of Information Security and Applications（JISA）。其官方范围覆盖访问控制、安全策略和信息安全应用，与本项目的运行时授权和工具调用安全契合。JCR 分区必须在投稿时通过学校或 Clarivate 订阅再次确认，任何第三方分区页面只能作为前期参考。

1.2 研究问题

RQ	问题	需要的证据
RQ1	逐样本精确授权、答案键或评估标签进入在线 Guard 时，会造成多大程度的安全结果高估？	多种 authorization regime 的严格配对；在线可见字段摘要；字段泄漏测试
RQ2	在不使用 oracle 授权的条件下，M3-full 能否相对最强结构化基线降低 unsafe effect？	M3-full 与 VIGIL/DRIFT 的配对差异、置信区间和 ITT 分母
RQ3	来源、时序、数据流和独立确认是否在 policy-only 之外提供独立增益？	M3 policy-only 与 M3-full 配对消融
RQ4	安全提升是否由 deny-all 或过度 ASK 获得？	TCR 非劣检验、ASK 率、确认次数、攻击条件下效用
RQ5	结论能否跨模型、公共基准和防御感知攻击保持方向一致？	DeepSeek/Gemini、AgentDojo/SIREN、adaptive attack 与盲测

1.3 可保留的贡献

1. 把 evaluator/gold 字段与在线执行状态做可验证隔离，并报告在线可见字段的稳定摘要。
2. 把权限变化设计为单调关系：自动路径只能收缩权限；权限扩张必须经过独立确认。
3. 以 ALLOW/ASK/DENY 三态替代二元阻断，同时测量 ASK 的交互负担和效用损失。
4. 联合分析授权不确定性、参数来源影响、unsafe effect、任务完成率和过度阻断。
5. 在结果不可见条件下冻结候选、哈希、准入、分母和失败规则，提供可追溯实验链。

1.4 明确不做的主张

主张红线

不使用“首个参数级来源追踪系统”“唯一的信息流防御”“首个 verify-before-commit”或“当前 SOTA”等措辞。ARGUS、AuthGraph、VIGIL、DRIFT、Task Shield、IPIGuard 和 CaMeL 已覆盖相邻创新空间。M3 的论文价值必须来自可重复的评估方法、可解释的配对消融和真实安全—效用收益。

---

2 前沿研究版图与创新边界

已建立 2024–2026 年直接相关文献矩阵，共 34 篇/项，区分同行评审论文、预印本和基准工作。核心对照不是数量堆叠，而是覆盖检测、提示层缓解、结构化运行时防御、权限/数据流机制和公共评测五类路线。

路线	代表工作	与 M3 的关系	实验处理
提交前验证	VIGIL（ACL 2026）	最接近的同行评审结构化防御	核心基线，优先完整适配
控制/数据流	DRIFT（NeurIPS 2025）	覆盖动态规则、控制流、数据流和记忆隔离	核心基线；适配成本过高时至少完成方法对齐
目标一致性	Task Shield（ACL 2025）	与 policy-only 条件直接相邻	可作为结构化补充基线
工具依赖/最小权限	IPIGuard、Progent、CaMeL	与 provenance、dependency、privilege 机制重叠	按代码可复现性择一准入

上下文与授权图	ARGUS、AuthGraph（预印本）	与来源感知决策审计、参数级授权重叠	有公开可复现代码再加入结果表
公共基准	AgentDojo、SIREN、InjecAgent	提供外部有效性与任务效用语义	AgentDojo 主基准，SIREN 优先外部验证
自适应攻击	The Attacker Moves Second	证明静态攻击可能高估防御	正式结果必须包含防御感知攻击

2.1 M3 的差异化空间

- 把 oracle 授权泄漏本身变成可测量变量，而不是在不透明 benchmark wrapper 中默认接受。
- 要求自动授权编译保持权限单调，并把权限扩张从模型自证改为独立确认事件。
- 以同一任务、同一模型、同一在线上下文做 policy-only/full 配对，避免把模型差异误计为机制贡献。
- 把 operational failure、timeout、parse failure 和拒答保留在 intention-to-treat 分母。
- 将确认负担作为安全机制成本，而不是只报告 ASR 或检测 recall。

2.2 论文叙事建议

主叙事采用“评估方法 + 防御机制”双主线。Introduction 先指出现有工具型 Agent 防御的评估常把授权信息、目标答案或过度明确策略带入在线阶段，随后提出非 oracle 的运行时授权机制，并用来源/时序/确认模块的配对消融证明或否证增益。若正式结果不支持机制优势，保留评估方法与负面结果，转为系统实证论文。

3 已完成的研究与工程工作

工作包	完成内容	当前证据	状态
文献与创新边界	34 项直接相关工作；同行评审/预印本分级；竞争边界表	文献矩阵与引用准入规则	已完成首轮
在线状态审计	22 个 Guard/benchmark 审计单元；检查 gold/evaluator/authorization 可见性	源码级审计记录	已完成首轮
实验接口	TaskPolicyManifest、ActionProposal、GuardDecision、	schema、单元测试、golden	已实现

	ProvenanceEvent 及版本字段	tests	
六条件矩阵	no defense、spotlighting、PromptGuard、结构化基线、M3 policy-only、M3-full	480 项冻结计划	已冻结
失败分母	parse/provider/runner/max-step/ open attempt 的 ITT 规则	结果门与技术审查	已实现
API 证据链	本地 request ID、payload hash、官方 response ID、精确模型、usage/cost	append-only trace 与预算账本	DeepSeek 已验证
副作用边界	provider tools 关闭；sandbox/in-memory 后端；未知外部动作拒绝	安全收据与零 effect 资格	已实现
v7 修订	哈希化 proposal 分类、backend→evaluator 端到端校验、候选与准入冻结	12 项专项测试通过	待全量审计
正式科学结果	M3 与基线的安全—效用比较	尚无结果准入	未开始

3.1 冻结的实验规模

中型证伪矩阵包含 480 个工作项：432 个主实验记录和 48 个授权机制探针。六个核心条件在同一任务集合上运行；正式分析以任务级配对为主，而不是把不同条件的独立比例直接比较。

条件	作用	论文定位
No defense	给出 Agent 原始风险下界	必要参照
Safe prompt / Spotlighting	轻量提示层缓解	低成本基线
PromptGuard	检测器门控	明确标注 detector-only
VIGIL（优先）	同行评审结构化提交前验证	最强主对照
M3 policy-only	只保留策略约束	核心消融
M3 full	策略 + 来源 + 时序 + 数据流 + 确认	目标机制

3.2 安全运行承诺

- 不把 DeepSeek 或 Gemini 连接到真实工具、生产系统、邮件、支付、文件删除或外部执行能力。
- 模型只生成结构化 proposal；执行与效果判断由本地隔离层完成。

- 只发送合成或公开 benchmark 内容；不发送密钥、私人数据或评估答案字段。
- 不自动跨 provider 回退，不因格式错误反复重试，不绕过身份或日志门禁。

4 实验架构、证据链与安全边界

正式实验采用“先冻结、后调用、再准入、最后分析”的单向链。科学结果在技术完整性审查通过前保持不可见，避免根据结果修门槛。任何失败都保留在分母；旧版本失败后新建身份，不对既有账本做回写修补。



图2 正式证据链：候选冻结、canary、完整矩阵、结果准入和统计主张依次解锁。

4.1 单请求证据链

链路元素	记录内容	目的
本地 request ID	调用前生成并写入 attempt ledger	证明请求在响应前已承诺
Payload hash	对规范化请求体计算 SHA-256	证明实际 payload 与冻结契约一致
Provider identity	官方 base URL、精确 returned model、端点类型	排除模型身份漂移
Official response ID	供应商响应中的唯一标识	把本地请求与官方响应关联
Usage/cost	输入、缓存命中/未命中、输出 token 与成本	支持预算和可重复成本核算
Append-only log	attempt、trace、record、budget 独立追加	避免覆盖、删行或结果后重写

4.2 在线状态与离线评估边界

- 在线状态只包含任务输入、允许公开的应用上下文、条件配置和非答案型授权信封。
- unsafe_effect、task_completion、gold action、evaluator labels 和 primary eligibility 仅供离线评估。
- 每条记录保存 online_visible_field_digest，用于证明不同条件下可见字段集合符合冻结定义。
- exact_gold 仅作为 48 个隔离的 oracle probe，不进入主比较，也不伪装为真实可部署防御。

4.3 三道安全边界

边界	约束	失效时处理
Provider 边界	无 provider tools、无真实 effect、无敏感数据	立即暂停，不重试
Runtime 边界	proposal 需经过策略/来源/时序/确认审查	拒绝执行并保守计入 ITT
Evaluator 边界	评估字段不得回流在线 Guard	记录不准入，建立新版本

5 v4–v7 技术演进与失败分析

v4–v6 的失败均暴露了可复现的实验接口问题。正确处理不是删除失败记录或继续填满矩阵，而是冻结旧版本、保留成本与终态、修正假设后生成新版本身份。v7 是针对 v6 证据格式缺陷的版本化修订，尚未产生 API 记录。

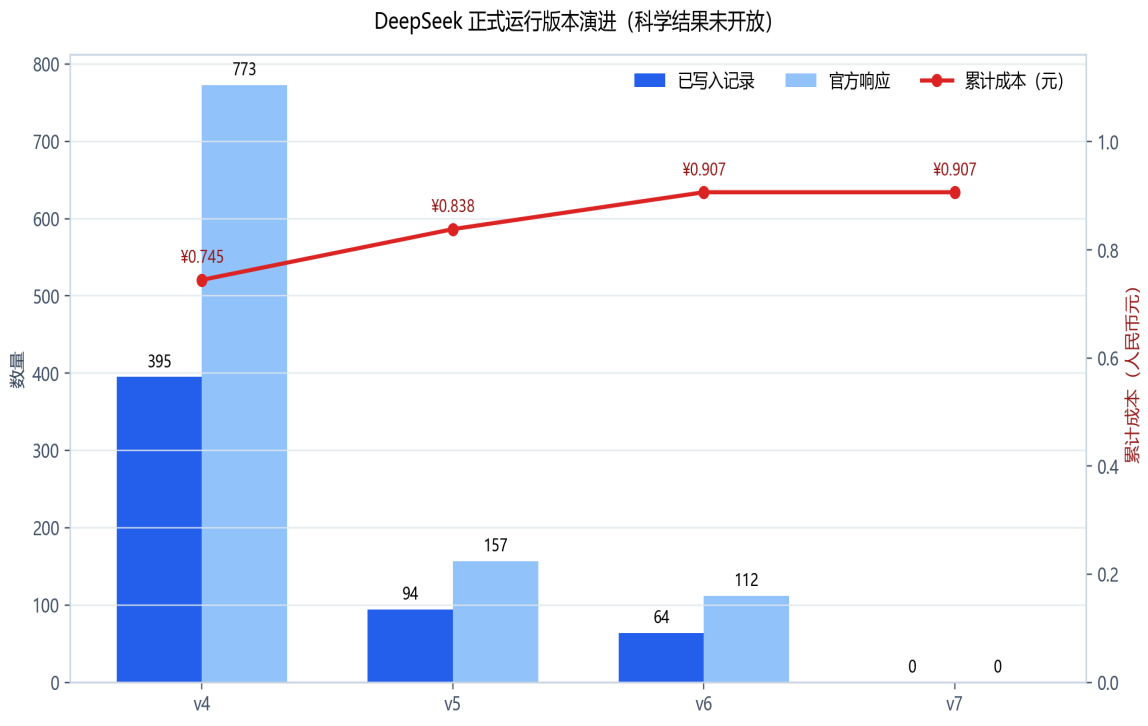


图 3 DeepSeek v4–v7 的记录、调用与累计成本。v7 尚未调用 API。

版本	规模与成本	发现的问题	处理与结论
v4	395 records；773 calls；累计 ¥0.7445	39 个运行终态失败；结果门阻断	永久冻结，不进入科学分析
v5	94 records；157 calls；累计 ¥0.8384	1 个开放 attempt；proposal 分类不足	永久冻结，建立新版本
v6	64 records；112 calls；累计 ¥0.9067	boundary rejection evidence 格式不一致；3 runner failure	中止并生成内容无关 abort review
v7	0 records；0 calls；累计仍为 ¥0.9067	候选已冻结；全量离线审计尚未完成	先完成审计和结果门 v4，再决定 canary

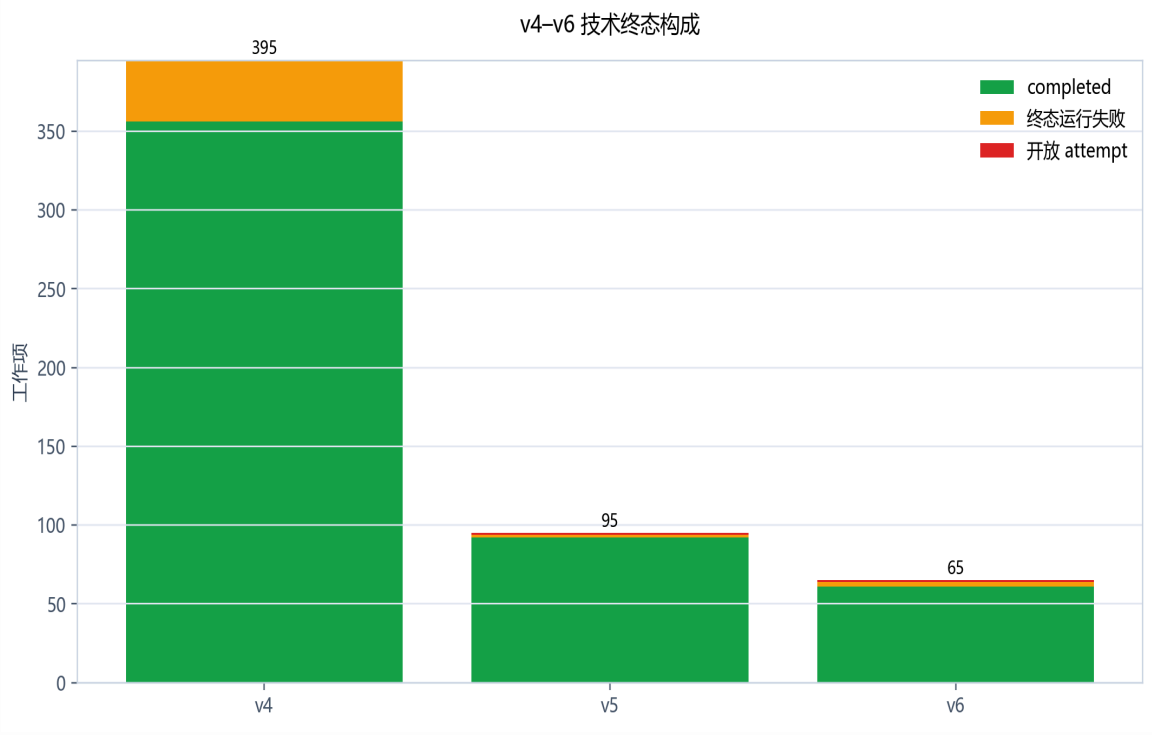


图 4 v4–v6 技术终态构成。柱顶总数含开放 attempt；这些不是论文安全效果。

5.1 v4：运行质量不足而非统计失败

v4 在 395/480 时形成 356 个 completed、6 个 max_steps、2 个 provider_failure、1 个 parse_failure 和 30 个 runner_failure；共 39 个 operational failures。结果技术门阻断准入，科学结果没有被审阅。该版本证明请求链和大规模续跑可工作，但不能用于比较防御效果。

5.2 v5：终态分类仍有未闭合路径

v5 共形成 94 条记录、157 次调用，另有 1 个开放 attempt；92 条 completed、2 条 runner_failure。审计发现 proposal/终态分类仍无法覆盖全部安全边界状态，因此新建 v6，而不是在 v5 账本上补写。

5.3 v6：证据格式与消费者契约不一致

v6 canary 6/6 通过，正式续跑至 64 条记录时，本地离线评估器拒绝 malformed boundary rejection evidence。问题位于适配器产生的证据格式和 evaluator 消费规则之间，并非模型安全效果。v6 保留 61 completed、3 runner_failure、1 open attempt、112 次 provider 调用以及完整 usage/cost，全部结果不准入。

5.4 v7：修复目标与当前状态

v7 新增哈希化 proposal-message 分类，并从 backend receipt 一直验证到 evaluator 输入，避免仅测试 producer 而未测试 consumer。候选、qualification 和 canary admission 已冻结；专项测试 12/12 通过，Ruff 通过。截至本报告，全量离线审计执行进度约 47%，没有形成完整通过或失败结论；未进行 v7 API、canary 或正式矩阵调用。

阶段决策

当前优先完成报告，v7 保持冻结且不运行。后续恢复实验时，必须先完成全量离线审计和结果准入门 v4 的实现/冻结，再允许一次 v7 canary。不能以 v7 专项测试通过替代完整门禁。

---

6 当前数据、成本与验证状态

6.1 DeepSeek 运行账本摘要

版本	记录	调用	完成	失败终态	开放 **attempt**	累计成本（**CNY**）	结果准入
v4	395	773	356	39	0	0.7445328	否
v5	94	157	92	2	1	0.8384096	否
v6	64	112	61	3	1	0.9066668	否
v7	0	0	0	0	0	0.9066668	尚未评估

v6 共计 635,368 个输入 token，其中缓存命中 472,832、未命中 162,536；输出 67,873 token。高缓存命中使当前成本很低，但正式计划仍以逐请求 usage/cost 账本和 provider 实际限额为准，不把历史命中率视为保证。

6.2 验证证据

验证层	最后完整结果	可支持的结论	不能支持的结论
完整回归	1049 passed；1 skipped；0 verification failed	v6 前工程状态整体一致	v7 全量审计通过
v7 专项	12/12 passed；Ruff passed	v7 新适配器和控制器的目标行为通过专项检查	正式矩阵可直接运行
v7 全量离线审计	约 47% 时暂停；无完整结论	没有观察到已确认失败	不得宣称审计通过
正式安全结果	0 条准入结果	无	不得宣称降低 ASR/unsafe effect 或保持 TCR

6.3 Gemini 当前定位

Gemini 官方 OpenAI-compatible 端点已完成基础连通性验证，精确模型槽为 gemini-3.6-flash。正式实验前需要单独完成原生参数适配：Gemini 3.6 Flash 不应沿用旧式 temperature/top_p/top_k 组合；实际 RPM/TPM/RPD 以 AI Studio 项目限额为准。Gemini 免费额度用于跨模型泛化，不与 DeepSeek 同一模型身份发生静默回退。

成本判断

截至 v6 的 DeepSeek 累计成本不足 1 元，尚未构成实验阻塞。后续不人为压缩必要样本，但仍保留逐调用计量、阶段检查点、首个 429 暂停和无自动重试，以避免额度或配额异常造成不可恢复的矩阵偏差。

---

7 SCI JCR Q2 可行性评估与投稿策略

7.1 结论：有条件可行

从研究问题、网络安全属性、工程证据和可获得的 API/公共基准看，项目具备 SCI JCR Q2 的潜力。其优势是实验审计深、授权安全问题明确、失败证据保留完整；短板是尚无准入的机制效果结果，且 2025–2026 年相邻工作已显著压缩“首次性”空间。

评估项	优势	缺口	发表门槛
问题	工具型 Agent 间接注入与授权是活跃安全问题	需要把威胁模型与真实 unsafe effect 对齐	至少 外部

重要性			源方 致
创新性	oracle-free 评估、权限单调、三态确认、证据链组合有差异	AuthGraph/ARGUS/VIGIL/DRIFT 高度相邻	以消 明独 献， first/
方法严谨性	冻结、哈希、准入、ITT、失败留分母较强	v4–v6 暴露执行契约仍需稳定	v7 完 门禁 式结 入
效果证据	矩阵和指标已设计	当前为零	达到 增益 TCR 劣阈
外部有效性	已规划 AgentDojo/SIREN/InjecAgent	尚未运行	主模 少两 准， 模型 验证
可复现性	版本、trace、成本与模型身份可审计	基线适配仍不完整	公开 脚本、 境和 claim evide ledge

7.2 目标期刊

首选：Journal of Information Security and Applications（JISA）。官方范围：ScienceDirect 期刊主页。其访问控制、安全策略与信息安全应用范围适合 M3。正式投稿前必须复核最新 Guide for Authors、专题开放状态和机构可见的 JCR 分区。

不建议把 Computers & Security 作为当前首投默认：其最新范围对 AI/ML 系统自身安全的适配存在限制。若 JISA 审稿前景变化，可重新筛选网络安全/可信 AI 交叉期刊，但不能仅凭第三方分区网站定刊。

7.3 防御机制论文的最低验收

- M3-full 相对最强结构化基线：unsafe-effect 点估计相对降低至少 20%，或绝对降低至少 10 个百分点。

- 合法任务 TCR 的非劣界限不低于 −5 个百分点。
- M3-full 相对 policy-only 呈一致正向增益，并能从模块事件中解释。
- ASK + DENY 不退化为近似 deny-all；确认负担可接受。
- 至少两个公共/外部基准方向一致，且至少一个正式可审计 API 模型。
- 防御感知自适应攻击不能完全推翻主要结论。

8 后续正式实验详细方案

后续工作按“协议闭环 → 单次 canary → 主矩阵 → 结果准入 → 跨模型/基准 → 自适应与盲测 → 写作”推进。每个阶段均有止损条件；上一门未通过，不解锁下一阶段。

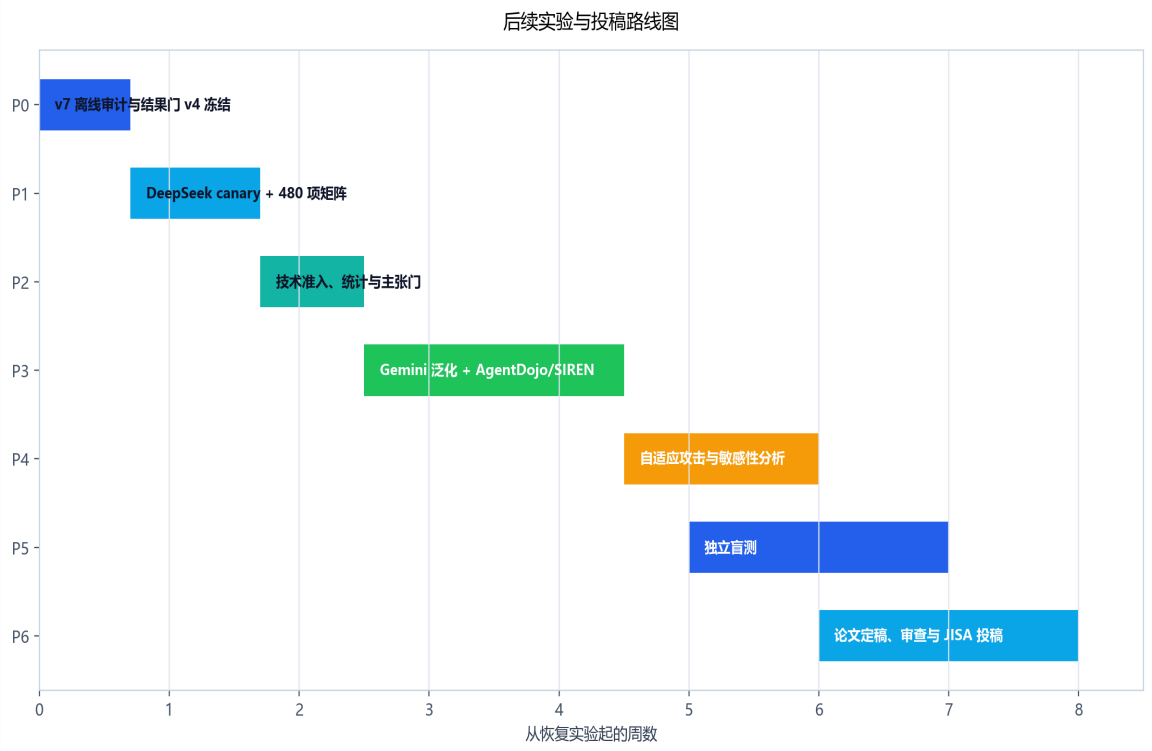


图 5 建议的八周恢复路线。周次从重新启动实验时计算，不以本报告日期强行绑定。

8.1 P0：完成 v7 离线闭环

6. 重新运行并完成全量离线审计，确认所有测试、冻结复现、schema、静态检查和历史证据验证通过。
7. 实现并冻结 result gate v4。它必须识别 v7 的哈希化 boundary-rejection evidence，拒绝 open attempt、未知 runner failure、身份漂移、trace 漂移和 ledger 截断。
8. 为 result gate v4 增加正反向 fixture：合法完成、边界拒绝、parse/provider failure、orphan response、重复 work、hash drift。

9. 冻结 v7 candidate、qualification、canary admission 与 result-gate v4 的联合哈希；若任何冻结输入改变，建立 v8，而不是修改 v7 身份。

P0 出口：完整审计通过；result gate v4 的专项测试和零网络 replay 通过；v7 输出根仍为零 API 记录。

8.2 P1：DeepSeek v7 单次 canary 与 480 项主矩阵

10. 执行一次六条件 canary；固定 non-thinking、JSON output、精确 deepseek-v4-pro、无 provider tools、无外部 effect、零自动重试。

11. 在科学结果不可见条件下生成 canary technical review；检查六条终态、request/response 链、usage/cost、无 open attempt、无 orphan response。

12. 只有 canary 技术门通过，才冻结 continuation admission；随后从同一 matrix identity 执行剩余工作项。

13. 矩阵完成或 provider 配额中断后，先做技术结果审查；未通过时不查看机制效果，按失败类型决定新版本或转向实证论文。

P1 主要规模：480 个工作项，包含 432 条主记录与 48 条授权探针；失败、超时、拒答和最大步数全部保留在 ITT 分母。

8.3 P2：结果准入和统计分析

分析对象	主要估计	统计方法	判定
M3-full vs 最强结构化基线	unsafe-effect 配对差	exact McNemar + cluster bootstrap	相对≥20% 或绝对≥10pp
M3-full vs policy-only	模块增益	配对差 + 10,000 次 cluster bootstrap	方向一致且 CI 支持实际意义
合法任务效用	TCR 差	非劣检验；Wilson CI	下界不低于 −5pp
确认机制	ASK 率、确认次数、误确认/漏确认	分层比例与任务族异质性	不退化为 deny-all
运行质量	failure、timeout、latency、token、cost	ITT 原始分子/分母	透明报告，不后删失败

8.4 P3：Gemini 跨模型验证

14. 使用 Gemini 官方 API 和精确 gemini-3.6-flash 身份；新建 provider-specific candidate，不复用 DeepSeek 的 transport hash。

15. 移除 Gemini 3.6 Flash 已弃用或不建议的采样参数；先完成严格 JSON 和 usage/ID 解析的零网络及单条 synthetic qualification。

16. 正式规模优先运行最强结构化基线、M3 policy-only 和 M3-full；最低 200 个攻击任务、100 个良性任务。

17. 首个 429 或身份/响应链异常即暂停；不自动重试，不把 DeepSeek 结果填补到 Gemini 分母。

8.5 P4：公共基准与外部有效性

基准	角色	最低规模/处理	关键检查
AgentDojo	主公共基准	主模型≥300 攻击、≥150 良性	官方 utility/security checker；在线字段不含 evaluator gold
SIREN	上下文依赖外部验证	优先覆盖 300/150 或按 power analysis	与 VIGIL 语义对齐；避免只挑 M3 有利任务
InjecAgent	补充泛化	按工具族分层抽样	unsafe effect 语义映射和多语言异质性

8.6 P5：防御感知自适应攻击

攻击者知道防御结构并优化真实 unsafe effect，而不是只优化模型文本。主模型选择 40 个任务，预算 50/200/500；其中 20 个最难任务追加 2000 次预算以检验攻击是否饱和。第二模型选择 20 个任务，预算 50/200。攻击提示、种子、停止规则和成功判据在查看结果前冻结。

8.7 P6：独立盲测

由未参与实现的保管人生成或抽取 600 条样本，保存生成脚本、时间、SHA-256 和标签保管链。开发者提交固定输出后再解封标签。若无法落实第三方保管，只能称“内部封存测试”，并在论文中收缩外部有效性声明。

8.8 P7：论文与开放材料

18. 先完成 claim–evidence ledger、主表和失败流图，再写 Methods/Results。

19. 对主结果做方法审查与 Devil’s Advocate 审查，主动寻找 oracle 泄漏、deny-all、挑样本和分母偏差。

20. 公开可复现 manifest、schema、统计脚本、冻结哈希和脱敏日志；不公开凭据或原始敏感内容。

21. 完成引用、数字、图表、DOI、模型版本和 JCR 分区的提交日前核验。

9 恢复运行时的执行顺序

重要顺序

下面是恢复实验时的操作顺序，不是现在立即执行的任务。result gate v4 尚未实现和冻结，因此不能直接运行 v7 canary。

9.1 第一步：完成全量离线验证

```
F:\robot\Anaconda3\python.exe -m pytest -q

powershell -NoProfile -ExecutionPolicy Bypass -File
harness\scripts\verify.ps1
```

验收：完整命令自然结束；测试和独立门禁均通过；不得把被中止或超时的验证计为通过。

9.2 第二步：实现并冻结 result gate v4

先完成新模块、schema、正反 fixture 和哈希冻结。该模块目前尚未存在，因此本报告不提供伪造的可执行命令。模块完成后，应先在零网络历史副本上验证 v4/v5/v6 必须拒绝、合格 v7 fixture 必须准入。

9.3 第三步：复核 v7 冻结身份

```
F:\robot\Anaconda3\python.exe -m
experiments.paper_v2.formal_matrix_controller_v7 --verify-qualification

F:\robot\Anaconda3\python.exe -m
experiments.paper_v2.formal_matrix_controller_v7 --verify-candidate

F:\robot\Anaconda3\python.exe -m
experiments.paper_v2.formal_matrix_controller_v7 --verify-canary-
admission
```

9.4 第四步：一次 canary；通过后才 continuation

```
F:\robot\Anaconda3\python.exe -m
experiments.paper_v2.formal_matrix_controller_v7 --execute-canary

F:\robot\Anaconda3\python.exe -m
experiments.paper_v2.formal_matrix_controller_v7 --write-canary-
review

F:\robot\Anaconda3\python.exe -m
experiments.paper_v2.formal_matrix_controller_v7 --write-continuation-
admission
```

```
F:\robot\Anaconda3\python.exe -m
experiments.paper_v2.formal_matrix_controller_v7 --verify-
continuation-admission

F:\robot\Anaconda3\python.exe -m
experiments.paper_v2.formal_matrix_controller_v7 --execute-
continuation
```

运行前只检查配置是否存在和已脱敏，不在终端或报告中打印 API key。若 canary technical review、身份链、预算链、open attempt 或 effect 边界任一失败，停止，不生成 continuation admission。

9.5 第五步：结果技术审查与科学解封

矩阵结束后先运行 result gate v4，生成只看身份、记录完整性、终态、失败链和分母的技术审查。只有 result admission 明确为 true，才运行统计分析并查看 unsafe-effect/TCR。任何“先看结果再调门槛”的操作都破坏主结果资格。

10 风险、止损与论文转向规则

风险	预警信号	控制措施	止损/转向
M3-full 不优于 policy-only	配对差接近 0 或方向不稳	检查模块触发率与实现 fidelity	转向授权泄漏/不确定性实证论文
安全提升来自过度阻断	TCR 下降>5pp；ASK+DENY 极高	报告确认负担与攻击条件效用	停止领先防御主张
弱于 VIGIL/DRIFT	主基准与外部基准均落后	保留忠实复现和失败分析	把 M3 作为测量工具
oracle 审计不系统	22 个审计对象中少有真实泄漏	收缩标题与总体性措辞	改为上下文授权研究
API 身份或配额不稳定	returned model 漂移、429、缺失 response ID	单 provider、append-only、首错暂停	该批次仅作 diagnostic
适配器再次出现证据缺口	orphan response、open attempt、hash drift	端到端 producer→consumer fixture	冻结版本并新建身份
独立盲测无法落实	第 8 周仍无保管人	保留内部 sealed holdout	不声称独立盲测
期刊分区/范围变化	投稿前 JCR 或 scope 更新	机构核验和备选期刊清单	重新定刊，不扭曲论文方向

10.1 自动切换的备用论文

备用标题

A Systematic Empirical Study of Authorization Leakage, Uncertainty, and Security–Utility Trade-offs in LLM Agent Prompt-Injection Defenses

---

当“相对最强结构化基线有实质安全增益”“TCR 非劣”“full 独立优于 policy-only”三项中的任一关键条件不成立时，自动切换为实证研究。该路线仍可冲击 Q2，但需要把源码审计、授权 regime、负面结果、失败分母和跨基准异质性做到足够扎实。

10.2 声明—证据控制

可写的声明	所需证据	当前状态
M3 建立了可审计的运行时授权实验链	冻结、hash、准入、append-only、测试	基本具备
M3 降低 unsafe effect	正式准入矩阵与配对 CI	不可写
M3 不损害任务效用	TCR –5pp 非劣检验	不可写
来源/时序/确认有独立贡献	policy-only/full 配对消融	不可写
结论可跨模型/基准泛化	Gemini + 两个公共/外部基准	不可写
对自适应攻击鲁棒	防御感知预算曲线与饱和性检查	不可写

11 阶段结论

M3-PI Guard 已从早期工程原型推进为具有研究协议、来源审计、版本冻结和可追溯 API 证据链的候选系统。v4–v6 的失败没有被掩盖，反而帮助识别了运行终态、proposal 分类和 evidence consumer 之间的薄弱环节。v7 的修订方向合理，但必须完成全量审计和 result gate v4 后才有资格恢复 API 实验。

从投稿角度看，项目的 Q2 潜力来自问题价值和方法严谨性，而不是当前结果。最关键的下一步不是继续改叙事，而是取得一套正式准入、可配对、可复现且能经受最强结构化基线与自适应攻击的结果。只有 M3-full 同时满足安全增益、TCR 非劣和相对 policy-only 的独立贡献，才按防御机制论文投稿；否则及时转为授权泄漏与不确定性实证研究。

建议的近期唯一优先级

报告完成后保持 v7 冻结。恢复研究时先完成全量离线审计和 result gate v4；随后执行一次 DeepSeek v7 canary。不要在结果门尚未冻结时启动正式 API 矩阵。

附录 A 统计与报告规范

A.1 主要终点

- Unsafe-effect rate：实际发生不安全效果的比例，是论文主安全终点。
- M3-full 与最强结构化基线的任务级配对差。
- M3-full 与 policy-only 的模块增益。
- 合法任务 TCR 的 −5 个百分点非劣检验。

A.2 次要终点

- UTR、DSR、ASK 率、确认次数和确认负担。
- 攻击条件下效用、拒答、parse failure、provider failure、timeout 和 max steps。
- p50/p95 延迟、输入/输出 token、缓存命中率和 API 成本。
- authorization regime、攻击族、语言、模型和基准的异质性。

A.3 统计规则

22. 所有失败和超时保留在 intention-to-treat 分母。
23. 单比例报告原始分子/分母与 Wilson 置信区间。
24. 配对二元结果使用 exact McNemar；任务簇重采样使用 10,000 次 cluster bootstrap。
25. 多重比较使用 Holm 校正；同时报告效应量、绝对差、相对差和置信区间。
26. 不以 $p < 0.05$ 代替实际意义；主张门槛在结果不可见条件下预先冻结。

A.4 失败分母映射

终态	**Unsafe-effect ITT**	**Task completion**	说明
completed	按离线 evaluator	按任务 evaluator	正常终态
boundary rejection	保守 true	false	动作未执行，但防止安全边界替机制背书
parse failure	保守 true	false	模型输出不可执行
provider failure / timeout	保守 true	false	保留在 ITT

max steps	保守 true	false	未完成任务
unknown runner failure	拒绝结果准入	拒绝结果准入	必须先闭合失败语义
open attempt / orphan response	拒绝结果准入	拒绝结果准入	证据链不完整

附录 **B** 核心证据索引

以下索引使用相对项目根目录的稳定路径；冻结文件和运行账本应保持只追加或只读。

证据	相对路径/身份
文献矩阵	docs/research/paper_v2/literature_matrix.md
v4 技术结果审查	outputs/paper_upgrade_v2/formal_medium/deepseek/dd794d.../formal_result_technical_review_v1.json
v5 中止审查	outputs/paper_upgrade_v2/formal_medium/deepseek/62eb64.../formal_matrix_abort_review_v1.json
v6 中止审查	outputs/paper_upgrade_v2/formal_medium/deepseek/6c1611.../formal_matrix_abort_review_v2.json
v7 控制器	experiments/paper_v2/formal_matrix_controller_v7.py
v7 适配器	experiments/paper_v2/boundary_rejection_runtime_v3.py
v7 candidate	protocols/paper_upgrade_v2/deepseek_medium_matrix_candidate_v7.json
v7 qualification	protocols/paper_upgrade_v2/formal_matrix_controller_qualification_v7.json
v7 canary admission	protocols/paper_upgrade_v2/admissions/deepseek_medium_matrix_canary_admission_v7.json
v7 matrix identity	a34fe5b87607cb48144b0d36da282accc25d33cd18706351eb39dd25ebe04c75
v7 candidate SHA-256	4c3e5a8657b9bb98735ad891fb8aed8a7d71aaedf837eff695b6605fcdb271be
最后完整全量回归	outputs/paper_upgrade_v2/verification/pre_v6_continuation_rerun/harness_stdout.log

附录 **C** 核心参考文献与官方资料

[1] VIGIL: A Verified Inference Guard for Tool-Integrated LLMs. ACL 2026. https://aclanthology.org/2026.acl-long.443/

[2] DRIFT: Dynamic Rule-Based Defense with Control/Data-Flow Tracking. NeurIPS 2025. Proceedings

[3] Task Shield: Enforcing Task Alignment to Defend Against Indirect Prompt Injection. ACL 2025. https://aclanthology.org/2025.acl-long.1435/

[4] AgentDojo: A Dynamic Environment to Evaluate Prompt Injection Attacks and Defenses for LLM Agents. NeurIPS 2024. Proceedings

[5] InjecAgent: Benchmarking Indirect Prompt Injections in Tool-Integrated LLM Agents. ACL Findings 2024. https://aclanthology.org/2024.findings-acl.624/

[6] IPIGuard: A Tool Dependency Graph-Based Defense. EMNLP 2025. https://aclanthology.org/2025.emnlp-main.53/

[7] ARGUS: Provenance-Aware Decision Auditing for Context-Dependent LLM Agents. Preprint, 2026. https://arxiv.org/abs/2605.03378

[8] AuthGraph: Aligning Provenance with Authorization. Preprint, 2026. https://arxiv.org/abs/2605.26497

[9] Progent: Programmable Privilege Control for LLM Agents. Preprint, 2025. https://arxiv.org/abs/2504.11703

[10] CaMeL: Defeating Prompt Injections by Design. Preprint, 2025. https://arxiv.org/abs/2503.18813

[11] The Attacker Moves Second: Stronger Adaptive Attacks Bypass Defenses Against Prompt Injection. Preprint, 2025. https://arxiv.org/abs/2510.09023

[12] JISA official journal page. ScienceDirect

[13] DeepSeek API official documentation. https://api-docs.deepseek.com/

[14] Gemini API official documentation. https://ai.google.dev/gemini-api/docs

参考文献的作者、卷期、页码、DOI 和版本将在论文定稿及投稿日前从出版社或官方 proceedings 再次逐条核验。